DOCENTE	Massimo Orengia
UNITA' FORMATIVA	Copyright e norme giuridiche del mondo digitale
ARGOMENTO	Slides Cloud Specialist – settima lezione

FONDAMENTI DI LICEITÀ DEL TRATTAMENTO



Quando il tratttamento dei dati è lecito?

Quando ha una “base giuridica”, cioè quando ricorre uno dei casi previsto dall’art. 6:

- **consenso espresso dell'interessato:**
- **Esempio Generale:** L'iscrizione a una newsletter di marketing di un negozio online.
- **Esempio ITS:** Lo studente firma un modulo per autorizzare l'Academy a pubblicare la sua foto sui canali social per promuovere un evento.

.

- **adempimento di obblighi contrattuali:**

  Esempio Generale: Una banca che tratta i dati del cliente per gestire il suo conto corrente.

  Esempio ITS: L'Academy gestisce i dati anagrafici e il codice fiscale dello studente per formalizzare l'iscrizione e permettergli di frequentare le lezioni.

- **obblighi di legge:**
  Esempio Generale: Un datore di lavoro che comunica i dati dei dipendenti all'Agenzia delle Entrate o all'INPS.
  Esempio ITS: L'Academy trasmette i dati di frequenza e i voti al Ministero dell'Istruzione e del Merito (piattaforma INDIRE) per il monitoraggio obbligatorio dei percorsi ITS.

- **salvaguardia degli interessi vitali della persona interessata o di terzi:**
  Esempio Generale: Un ospedale che accede alla cartella clinica di un paziente in stato di incoscienza dopo un incidente.
  Esempio ITS: Uno studente ha un malore improvviso in aula; lo staff dell'ITS comunica i suoi dati sanitari (se noti, come allergie) ai soccorritori del 118.

- **interesse pubblico o esercizio di pubblici poteri da parte del titolare:**
  Esempio Generale: La gestione dell'anagrafe comunale o il controllo della viabilità tramite telecamere della Polizia.
  Esempio ITS: La gestione dei dati per lo svolgimento degli esami di Stato finali per il rilascio del Diploma di Tecnico Superiore.

- **interesse legittimo:**

- **Esempio Generale:** Un'azienda che installa telecamere di videosorveglianza per prevenire furti nel proprio magazzino.
- **Esempio ITS:** L'invio di email agli ex-studenti (Alumni) per informarli di nuove opportunità di lavoro o career day, basandosi sull'interesse dell'ente a favorire l'occupazione dei propri diplomati.

Attenzione: Questo è il punto più critico. Il Garante Italiano e il GDPR impongono un "test di bilanciamento": se i dati raccolti sono troppo invasivi per la privacy dell'utente, il legittimo interesse decade.

In altre parole, il legittimo interesse del titolare o del terzo, per costituire un valido fondamento di liceità, deve prevalere sui diritti e le libertà fondamentali dell’interessato.


INFORMATIVA

Informativa (artt. 13 e 14 GDPR)

Il titolare dei dati personali deve sempre ricevere l'INFORMATIVA, cioè il documento che contiene tutte le informazioni relative all'utilizzo dei suoi dati personali.

l'informativa deve avere forma concisa, trasparente, intelligibile per l'interessato e essere facilmente accessibile, e deve specificare:

Identità e dati di contatto del Titolare

- **Esempio Generale:** "Il Titolare è l'Azienda *Alpha S.r.l.*, con sede in Via Roma 1, Milano."
- **Esempio ITS:** "Il Titolare del trattamento è la *Fondazione ITS Academy [Nome]* nella persona del suo legale rappresentante pro tempore."

Dati di contatto del DPO (Data Protection Officer)

La figura (se nominata) che vigila sul rispetto della privacy.

Finalità e Base Giuridica

Perché tratti i dati e su quale pilastro dell'Art. 6 ti appoggi.

- **Esempio Generale:** "I dati sono trattati per l'invio della merce acquistata (esecuzione contratto)."
- **Esempio ITS:** "I dati sono trattati per la gestione del registro elettronico e la valutazione degli apprendimenti (obbligo legale/compito pubblico)."

Destinatari o categorie di destinatari

A chi vengono comunicati i dati all'esterno dell'organizzazione.

- **Esempio Generale:** "I tuoi dati saranno comunicati al corriere espresso per la consegna del pacco."
- **Esempio ITS:** "I tuoi dati saranno comunicati alle aziende partner dove svolgerai lo stage per l'attivazione della convenzione."

Periodo di conservazione

Per quanto tempo i dati resteranno nei tuoi archivi.

- **Esempio Generale:** "I dati di fatturazione vengono conservati per 10 anni come previsto dalla normativa fiscale."
- **Esempio ITS:** "Il fascicolo dello studente (voti e diplomi) viene conservato illimitatamente poiché costituisce atto pubblico d'archivio."

Diritti dell'interessato

Cosa può fare l'utente (accesso, rettifica, cancellazione, ecc.).

- **Esempio Generale:** "Hai il diritto di chiedere la cancellazione del tuo account e dei dati associati in qualsiasi momento."
- **Esempio ITS:** "Puoi richiedere in ogni momento la rettifica dei tuoi dati anagrafici se risultano errati nei nostri database."

Natura del conferimento (Obbligatorio o Facoltativo)

Cosa succede se l'utente non fornisce i dati.

- **Esempio Generale:** "Il conferimento della mail è facoltativo, ma senza di essa non potrai ricevere lo sconto di benvenuto."
- **Esempio ITS:** "Il conferimento dei dati del titolo di studio è obbligatorio: in mancanza, non è possibile procedere all'immatricolazione al corso."

Diritto di proporre reclamo all’autorità di controllo

- Se ritengo che i miei dati non siano trattati secondo le regole del GDPR, posso proporre reclamo a Garante per la Protezione dei Dati Personali accedendo al sito e seguendo le istruzioni.


APPROCCIO BASATO SUL
RISCHIO E MISURE DI
ACCOUNTABILITY DI
TITOLARI E RESPONSABILI
GDPR

Dal "Cosa devo fare" al

"Come dimostro di averlo fatto"

Accountability (Responsabilizzazione)

A differenza delle vecchie leggi sulla privacy, che fornivano un elenco di "misure minime" da realizzare, il GDPR dice al Titolare: *"Non ti dico io esattamente cosa fare, ma sei tu che devi decidere le misure adeguate, applicarle e, soprattutto, essere in grado di dimostrare che funzionano"*.

In sintesi, l'accountability si basa su due pilastri:

1. **Adozione di misure** tecniche e organizzative adeguate al rischio.
2. **Capacità di dimostrare** l'efficacia di tali misure in caso di controllo.
    -

Strumenti di Accountability: 1. La DPIA

Quando un trattamento presenta un rischio elevato, il Titolare deve eseguire, prima di trattare i dati, la DPIA (Data Proteceion Impact Assesment) o Valutazione di Impatto sulla Protezione dei Dati. E' obbligatoria nei casi di:

- profilazione sistematica,

- trattamento su larga scala di dati sensibili (giudiziari, biometrici, sanitari),

- monitoraggio sistematico di zone pubbliche

- **Esempio Generale:** Una catena di supermercati che vuole introdurre un sistema di riconoscimento facciale per il marketing deve prima redigere una DPIA per valutare l'impatto sulla libertà dei clienti.
- **Esempio ITS:** L'Academy decide di installare un sistema di **rilevazione biometrica** (impronta digitale) per registrare le presenze degli studenti in aula. Prima di farlo, deve eseguire una valutazione d'impatto per dimostrare che non esistano metodi meno invasivi e che i dati biometrici siano protetti efficacemente.

Strumenti di Accountability:

2. Registro delle attività di trattamento

È il documento che mappa tutti i flussi di dati all'interno di un'organizzazione.

- **Esempio Generale:** Un'azienda di e-commerce tiene un registro aggiornato che indica chi ha accesso ai dati delle carte di credito, dove sono salvati i server e per quanto tempo vengono conservati i log di navigazione.
- **Esempio ITS:** La Fondazione ITS mantiene un registro dove specifica come vengono gestiti i dati sensibili (es. certificazioni di disabilità per prove d'esame personalizzate), chi può visualizzarli tra il personale di segreteria e quali misure di sicurezza (es. cartelle criptate) sono adottate.
    -

Strumenti di Accountability:

3. Formazione del Personale

Non basta avere software sicuri; le persone devono sapere come usarli.

- **Esempio Generale:** Una società di assicurazioni organizza corsi trimestrali per i dipendenti su come riconoscere le email di phishing che potrebbero compromettere i dati dei clienti.
- **Esempio ITS:** L'ITS organizza un seminario specifico per i **Tutor di Stage** e i docenti, spiegando loro che non possono condividere i voti degli studenti su gruppi WhatsApp non protetti o lasciare i verbali d'esame incustoditi in aula.

Privacy by Design e by Default

Il GDPR prevede che il corretto trattamento dei dati personali sia ispirato ai principi di Privacy By Design e By Defalut.

Sono obblighi del GDPR che impongono di integrare la tutela dei dati personali sin dalla progettazione (design) di un prodotto/servizio e di impostare automaticamente il massimo livello di riservatezza (default), minimizzando la raccolta dati e garantendo trasparenza e sicurezza per l'utente.

- **By Design** riguarda la **struttura** (come costruisco il sistema).
- **By Default** riguarda l'**utilizzo** (quanti dati prelevo e come li imposto all'inizio).

Privacy by Design

(Protezione fin dalla progettazione)

Il GDPR prevede che la protezione dei dati non sia un "aggiustamento" fatto alla fine, ma un elemento integrato fin dalla fase di ideazione di un progetto, software o servizio.

- **Il concetto:** Prima di lanciare un'app, devi pensare a come proteggere i dati. Se progetti un sistema che non può garantire la sicurezza, non devi farlo partire.
- **Esempio Generale:** Una software house che sviluppa un'app di messaggistica inserisce la **crittografia end-to-end** già nella prima riga di codice, impedendo a chiunque (anche agli sviluppatori) di leggere i messaggi.
- **Esempio ITS:** L'Academy decide di creare un nuovo **portale per il Placement**. In fase di progettazione, stabilisce che le aziende non vedano nome e cognome dei candidati, ma solo le loro competenze tecniche (CV anonimizzato), finché lo studente non accetta un colloquio.

Privacy by Default

(Protezione per impostazione predefinita)

Questo principio stabilisce che, per impostazione predefinita, devono essere trattati **solo i dati necessari** per la specifica finalità.

- **Il concetto:** Se un'opzione non è indispensabile, deve essere disattivata. Meno dati raccogli, meno rischi corri.
- **Esempio Generale:** Quando crei un profilo su un nuovo Social Network, il tuo profilo è impostato come **"Privato"** di default. Devi essere tu, con un'azione volontaria, a decidere di renderlo pubblico.
- **Esempio ITS:** Nel modulo di iscrizione online ai test d'ingresso, i campi come "Hobby" o "Link ai profili social" **non sono contrassegnati come obbligatori**. Il sistema permette l'invio della domanda compilando solo i dati strettamente necessari all'identificazione e alla valutazione scolastica.